

Conformidade (software livre, IDE-Defesa, LGPD)

RNF-09 exige três coisas: software exclusivamente livre com licença declarada, aderência à Portaria GM-MD nº 2.445/2021 (IDE-Defesa) quanto a padronização/metadados/regras de acesso, e aderência à LGPD quanto a minimização e não exposição de dado pessoal. Este documento descreve **as medidas técnicas concretas** tomadas em cada frente. Ele não substitui uma análise jurídica formal — para um sistema que vai operar em produção num órgão de defesa, recomendamos que a assessoria jurídica/compliance do órgão valide este documento contra o texto normativo vigente antes da homologação.

Software livre

Componente	Licença	Observação
PostgreSQL	PostgreSQL License (estilo MIT)	
PostGIS	GPL-2.0	
GeoServer	GPL-2.0	
FastAPI, SQLAlchemy, GeoAlchemy2, Alembic, Pydantic, PyJWT, passlib, Shapely, GeoPandas, ReportLab	MIT/BSD/Apache-2.0 (ver backend/requirements.txt)	
React, React Router, Leaflet, Leaflet.draw, TanStack Query	MIT	
nginx	BSD-2-Clause	
Este projeto (SISCOORD-DC)	MIT — ver <code>LICENSE</code>	

Nenhuma dependência do projeto é software proprietário/fechado. Antes de adicionar qualquer nova dependência, confira a licença (`pip show <pacote>` ou o `package.json` /registro do npm) e atualize esta tabela.

Portaria GM-MD nº 2.445/2021 (IDE-Defesa)

A portaria estrutura a Infraestrutura de Dados Espaciais da Defesa, alinhada à INDE e aos padrões OGC/ISO para padronização, metadados e regras de acesso a dados geoespaciais de defesa. Medidas correspondentes neste projeto:

- **Padronização.** As camadas operacionais são publicadas via GeoServer em WMS 1.3.0 e WFS 2.0.0 (RF-11) — os mesmos padrões OGC que a INDE/IDE-Defesa usa para interoperabilidade entre órgãos. O sistema de referência é declarado explicitamente em toda saída (SIRGAS 2000 / EPSG:4674, RNF-02), em vez de assumido implicitamente.
- **Metadados.** Cada camada publicada no GeoServer carrega título e SRS declarados (ver `geoserver/init_geoserver.sh`). Para produção, recomendamos completar os metadados de cada camada no console do GeoServer (resumo, palavras-chave, contato) seguindo o perfil de metadados adotado pela IDE-Defesa/INDE — isso é configuração de dados, não código, então fica fora do escopo deste repositório.
- **Regras de acesso.** RBAC de três perfis (RF-12) controla quem lê e quem escreve; a trilha de auditoria (RF-13) torna todo acesso de escrita rastreável. Dados sensíveis de posicionamento de recursos de defesa civil ficam atrás de autenticação — não há endpoint público sem login, **inclusive as camadas OGC**: toda requisição a `/geoserver/*` passa antes pela API (`auth_request` no nginx → `GET /api/auth/verificar-ogc`), que só libera usuário ativo — pelo cookie de sessão do mapa, por HTTP

Basic (clientes SIG como o QGIS) ou por token `Bearer`. A porta direta do GeoServer (8080), que não passa por essa verificação, só escuta no `127.0.0.1` do servidor e serve apenas à administração local. Ver `backend/app/auth/acesso_ogc.py` e `nginx/nginx.conf`.

LGPD — minimização e não exposição de dado pessoal

O sistema foi desenhado para precisar do mínimo de dado pessoal possível:

- **O que é coletado sobre pessoas:** só o necessário para autenticação e responsabilização de quem opera o sistema — nome, e-mail e senha (com hash+sal, nunca em texto claro) de cada usuário cadastrado (`usuarios`, RF-12). Não há cadastro de vítimas, moradores, ou qualquer civil identificável em nenhuma tabela do schema.
- **O que os "recursos" armazenam:** equipes, instalações e equipamentos são entidades operacionais (viaturas, abrigos, equipes) — o schema não tem campo para CPF, endereço residencial ou qualquer outro identificador de pessoa física além do necessário para a equipe de defesa civil (RF-01). Se a operação de vocês precisar registrar o nome de integrantes de uma equipe, trate isso como dado pessoal: crie uma tabela separada com controle de acesso próprio, em vez de um campo texto livre em `recursos`.
- **Auditoria (RF-13) e dado pessoal.** A trilha de auditoria guarda `usuario_id` (quem fez a ação) para todas as tabelas de negócio — isso é o mínimo necessário para responsabilização (accountability), um dos fundamentos da própria LGPD (art. 6º, X), não um excesso.
- **Retenção.** O schema não implementa expurgo automático de auditoria antiga. Se o órgão tiver uma política de retenção definida, implemente-a como uma rotina de banco (`DELETE FROM auditoria WHERE criado_em < ...`) — deliberadamente não incluímos isso por padrão, porque apagar trilha de auditoria é uma decisão de governança, não uma decisão técnica que o código deveria tomar sozinho.
- **Compartilhamento com terceiros.** A única saída de dados para fora do sistema é: (a) o WMS/WFS do GeoServer, acessível só a usuários autenticados, que expõe só os campos de `recursos / ocorrencias` publicados como camada — nenhum campo de `usuarios` é publicado ali; e (b) consumo de um WMS externo (RF-15), que é unidirecional (o sistema *lê* de fora, não envia nada).

Checklist antes de ir para produção

- ☐ Assessoria jurídica do órgão revisou este documento contra o texto vigente da Portaria GM-MD nº 2.445/2021 e da LGPD.
- ☐ Metadados de cada camada GeoServer completados conforme o perfil adotado pela IDE-Defesa/INDE.
- ☐ Política de retenção de `auditoria` definida e implementada, se aplicável.
- ☐ Certificado TLS de produção instalado (não o autoassinado de desenvolvimento — ver manual-`instalacao.md`).
- ☐ Todos os segredos do `.env` trocados dos valores de exemplo.